



ZAP by Checkmarx Scanning Report 5/18/26

Sites: <https://data-edge.smartscreen.microsoft.com> <https://telem-edge.smartscreen.microsoft.com> <https://nav-edge.smartscreen.microsoft.com> <https://edge.microsoft.com> <http://localhost:5173>

Generated on Mon, 18 May 2026 01:03:00

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	1
Medium	3
Low	3
Informational	3
False Positives:	0

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap. log file for details	8
Low	Warning		ZAP warnings logged - see the zap. log file for details	31
Info	Informational		Percentage of network failures	9 %
Info	Informational	http://localhost:5173	Percentage of responses with status code 2xx	47 %
Info	Informational	http://localhost:5173	Percentage of responses with status code 3xx	12 %
			Percentage of	

Info	Exceeded Low	http://localhost:5173	responses with status code 4xx	24 %
Info	Exceeded Low	http://localhost:5173	Percentage of responses with status code 5xx	14 %
Info	Informational	http://localhost:5173	Percentage of endpoints with content type image/svg+xml	16 %
Info	Informational	http://localhost:5173	Percentage of endpoints with content type text/html	2 %
Info	Informational	http://localhost:5173	Percentage of endpoints with content type text/javascript	95 %
Info	Informational	http://localhost:5173	Percentage of endpoints with method GET	100 %
Info	Informational	http://localhost:5173	Count of total endpoints	113
Info	Informational	https://data-edge.smartscreen.microsoft.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://data-edge.smartscreen.microsoft.com	Percentage of endpoints with content type application/octet-stream	100 %
Info	Informational	https://data-edge.smartscreen.microsoft.com	Percentage of endpoints with method POST	100 %
Info	Informational	https://data-edge.smartscreen.microsoft.com	Count of total endpoints	2

Info	Informational	https://data-edge.smartscreen.microsoft.com	Percentage of slow responses	100 %
Info	Informational	https://edge.microsoft.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://edge.microsoft.com	Percentage of endpoints with content type application/json	100 %
Info	Informational	https://edge.microsoft.com	Percentage of endpoints with method GET	50 %
Info	Informational	https://edge.microsoft.com	Percentage of endpoints with method POST	50 %
Info	Informational	https://edge.microsoft.com	Count of total endpoints	2
Info	Informational	https://edge.microsoft.com	Percentage of slow responses	50 %
Info	Informational	https://nav-edge.smartscreen.microsoft.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://nav-edge.smartscreen.microsoft.com	Percentage of endpoints with content type application/json	100 %
Info	Informational	https://nav-edge.smartscreen.microsoft.com	Percentage of endpoints with method POST	100 %
Info	Informational	https://nav-edge.smartscreen.microsoft.com	Count of total endpoints	1
Info	Informational	https://nav-edge.smartscreen.microsoft.com	Percentage of slow responses	7 %

Info	Informational	https://telem-edge.smartscreen.microsoft.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://telem-edge.smartscreen.microsoft.com	Percentage of endpoints with method POST	100 %
Info	Informational	https://telem-edge.smartscreen.microsoft.com	Count of total endpoints	1
Info	Informational	https://telem-edge.smartscreen.microsoft.com	Percentage of slow responses	100 %

Alerts

Name	Risk Level	Number of Instances
Path Traversal	High	2
Content Security Policy (CSP) Header Not Set	Medium	3
Missing Anti-clickjacking Header	Medium	3
Sub Resource Integrity Attribute Missing	Medium	1
Strict-Transport-Security Header Not Set	Low	6
Timestamp Disclosure - Unix	Low	2
X-Content-Type-Options Header Missing	Low	Systemic
Information Disclosure - Sensitive Information in URL	Informational	1
Information Disclosure - Suspicious Comments	Informational	43
Modern Web Application	Informational	3

Alert Detail

High	Path Traversal
Description	The Path Traversal attack technique allows an attacker access to files, directories, and commands that potentially reside outside the web document root directory. An attacker may manipulate a URL in such a way that the web site will execute or reveal the contents of arbitrary files anywhere on the web server. Any device that exposes an HTTP-based interface is potentially vulnerable to Path Traversal. Most web sites restrict user access to a specific portion of the file-system, typically called the "web document root" or "CGI root" directory. These directories contain the files intended for user access and the executable necessary to drive web application functionality. To access files or execute commands anywhere on the file-system, Path Traversal attacks will utilize the ability of special-characters sequences. The most basic Path Traversal attack uses the "../" special-character sequence to alter the resource location requested in the URL. Although most popular web servers will prevent this technique from escaping the web document root, alternate encodings of the "../" sequence may help bypass the security filters. These method variations include valid and

	invalid Unicode-encoding ("..%u2216" or "..%c0%af") of the forward slash character, backslash characters ("..\") on Windows-based servers, URL encoded characters "%2e%2e%2f"), and double URL encoding ("..%255c") of the backslash character. Even if the web server properly restricts Path Traversal attempts in the URL path, a web application itself may still be vulnerable due to improper handling of user-supplied input. This is a common problem of web applications that use template mechanisms or load static text from files. In variations of the attack, the original URL parameter value is substituted with the file name of one of the web application's dynamic scripts. Consequently, the results can reveal source code because the file is interpreted as text instead of an executable script. These techniques often employ additional special characters such as the dot (".") to reveal the listing of the current working directory, or "%00" NULL characters in order to bypass rudimentary file extension checks.
URL	http://localhost:5173/.vite-cache/deps/chunk-G3PMV62Z.js?v=%2Fchunk-G3PMV62Z.js
Node Name	http://localhost:5173/.vite-cache/deps/chunk-G3PMV62Z.js (v)
Method	GET
Attack	/chunk-G3PMV62Z.js
Evidence	
Other Info	
URL	http://localhost:5173/.vite-cache/deps/react.js?v=%2Freact.js
Node Name	http://localhost:5173/.vite-cache/deps/react.js (v)
Method	GET
Attack	/react.js
Evidence	
Other Info	
Instances	2
Solution	Assume all input is malicious. Use an "accept known good" input validation strategy, i.e., use an allow list of acceptable inputs that strictly conform to specifications. Reject any input that does not strictly conform to specifications, or transform it into something that does. Do not rely exclusively on looking for malicious or malformed inputs (i.e., do not rely on a deny list). However, deny lists can be useful for detecting potential attacks or determining which inputs are so malformed that they should be rejected outright. When performing input validation, consider all potentially relevant properties, including length, type of input, the full range of acceptable values, missing or extra inputs, syntax, consistency across related fields, and conformance to business rules. As an example of business rule logic, "boat" may be syntactically valid because it only contains alphanumeric characters, but it is not valid if you are expecting colors such as "red" or "blue." For filenames, use stringent allow lists that limit the character set to be used. If feasible, only allow a single "." character in the filename to avoid weaknesses, and exclude directory separators such as "/". Use an allow list of allowable file extensions. Warning: if you attempt to cleanse your data, then do so that the end result is not in the form that can be dangerous. A sanitizing mechanism can remove characters such as '.' and ';' which may be required for some exploits. An attacker can try to fool the sanitizing mechanism into "cleaning" data into a dangerous form. Suppose the attacker injects a '.' inside a filename (e.g. "sensi.tiveFile") and the sanitizing mechanism removes the character resulting in the valid filename, "sensitiveFile". If the input data are now assumed to be safe, then the file may be compromised. Inputs should be decoded and canonicalized to the application's current internal representation before being validated. Make sure that your application does not decode the same input twice. Such errors could be used to bypass allow list schemes by introducing dangerous inputs after they have been checked.

	Use a built-in path canonicalization function (such as <code>realpath()</code> in C) that produces the canonical version of the pathname, which effectively removes "." sequences and symbolic links. Run your code using the lowest privileges that are required to accomplish the necessary tasks. If possible, create isolated accounts with limited privileges that are only used for a single task. That way, a successful attack will not immediately give the attacker access to the rest of the software or its environment. For example, database applications rarely need to run as the database administrator, especially in day-to-day operations. When the set of acceptable objects, such as filenames or URLs, is limited or known, create a mapping from a set of fixed input values (such as numeric IDs) to the actual filenames or URLs, and reject all other inputs. Run your code in a "jail" or similar sandbox environment that enforces strict boundaries between the process and the operating system. This may effectively restrict which files can be accessed in a particular directory or which commands can be executed by your software. OS-level examples include the Unix <code>chroot</code> jail, AppArmor, and SELinux. In general, managed code may provide some protection. For example, <code>java.io.FilePermission</code> in the Java <code>SecurityManager</code> allows you to specify restrictions on file operations. This may not be a feasible solution, and it only limits the impact to the operating system; the rest of your application may still be subject to compromise.
Reference	https://owasp.org/www-community/attacks/Path_Traversal https://cwe.mitre.org/data/definitions/22.html
CWE Id	22
WASC Id	33
Plugin Id	6

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://localhost:5173/
Node Name	http://localhost:5173/
Method	GET
Attack	
Evidence	
Other Info	
URL	http://localhost:5173/robots.txt
Node Name	http://localhost:5173/robots.txt
Method	GET
Attack	
Evidence	
Other Info	
URL	http://localhost:5173/sitemap.xml

Node Name	http://localhost:5173/sitemap.xml
Method	GET
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	Missing Anti-clickjacking Header
Description	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
URL	http://localhost:5173/
Node Name	http://localhost:5173/
Method	GET
Attack	
Evidence	
Other Info	
URL	http://localhost:5173/robots.txt
Node Name	http://localhost:5173/robots.txt
Method	GET
Attack	
Evidence	
Other Info	
URL	http://localhost:5173/sitemap.xml
Node Name	http://localhost:5173/sitemap.xml
Method	GET
Attack	
Evidence	
Other Info	

Instances	3
Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

Medium	Sub Resource Integrity Attribute Missing
Description	The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content.
URL	http://localhost:5173/src/utis/reportTemplates.js
Node Name	http://localhost:5173/src/utis/reportTemplates.js
Method	GET
Attack	
Evidence	<script src="https://cdn.plot.ly/plotly-2.32.0.min.js">
Other Info	
Instances	1
Solution	Provide a valid integrity attribute to the tag.
Reference	https://developer.mozilla.org/en-US/docs/Web/Security/Subresource_Integrity
CWE Id	345
WASC Id	15
Plugin Id	90003

Low	Strict-Transport-Security Header Not Set
Description	HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol specified in RFC 6797.
URL	https://edge.microsoft.com/serviceexperimentation/v3/?osname=win&channel=stable&osver=10.0.17763.1000&devicefamily=desktop&installdate=1767830724&clientversion=148.0.3967.70&experimentationmode=2&scpguard=0&scpfll=0&scpver=0
Node Name	https://edge.microsoft.com/serviceexperimentation/v3/ (channel,clientversion,devicefamily,experimentationmode,installdate,osname,osver,scpfll,scpguard,scpver)
Method	GET
Attack	
Evidence	
Other Info	
URL	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/settings/3
Node	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/settings/3 (){{identity:{user:device:{id,customId,onlinedTicket,family,locale,osVersion,browser:{internetExplorer},netJoinSta

Name	enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUris,edgeSettings,customSettings}}},correlationId,debugInfo:{clientI
Method	POST
Attack	
Evidence	
Other Info	
URL	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/toptraffic/3
Node Name	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/toptraffic/3)({identity:{user device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinSta enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUris,edgeSettings,customSettings}}},correlationId,debugInfo:{clientI
Method	POST
Attack	
Evidence	
Other Info	
URL	https://edge.microsoft.com/componentupdater/api/v1/update?cup2key=7:j9ld7_4OrmyCXKMl9t6eqGQRZxPH-ZvloIEz5_jvnBc&cup2hreq=1badcc64097a8c682dcdb5005578dae26db2c0eb74cc6f00f6cf24c8
Node Name	https://edge.microsoft.com/componentupdater/api/v1/update (cup2hreq,cup2key)({request:{@os @updater,acceptformat,apps:[{appid,brand,cohort,enabled,installdate,lang,ping:{r},targetingattri {AppCohort,AppMajorVersion,AppRollout,AppVersion,IsInternalUser,Priority,Updater,UpdaterVe updatecheck:{},version}},arch,dedup,domainjoined,hw:{avx,physmemory,sse,sse2,sse3,sse41,s sse3},ismachine,os:{arch,platform,version},prodversion,protocol,requestid,sessionid,updaters: {autoupdatecheckenabled,ismachine,lastchecked,laststarted,name,updatepolicy,version}, updaterversion}))
Method	POST
Attack	
Evidence	
Other Info	
URL	https://nav-edge.smartscreen.microsoft.com/api/browser/edge/navigate/3
Node Name	https://nav-edge.smartscreen.microsoft.com/api/browser/edge/navigate/3)({userAgent,redirect enhancedRedirectChain:{redirectSource,referrerChain:[]},identity:{user:{locale},device:{id,custor onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},clo architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLoc edgeSettings,customSettings}}},config:{user:{uriReputation:{enforcedByPolicy,level}},device:{ap {level},appReputation:{enforcedByPolicy,level}}},destination:{uri,ip},...)
Method	POST
Attack	
Evidence	
Other Info	
URL	https://telem-edge.smartscreen.microsoft.com/api/browser/edge/telemetry/3
Node Name	https://telem-edge.smartscreen.microsoft.com/api/browser/edge/telemetry/3)({executionTime,r samplingRates:{evaluateModel,serverCall},config:{user:{uriReputation:{enforcedByPolicy,level}} {appControl:{level},appReputation:{enforcedByPolicy,level}}},correlationId,identity:{user:{locale}, {id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,ent },cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic, customSynchronousLookupUris,edgeSettings,customSettings}}},userAgent,events:{{\$type,nam.
Method	POST

Attack	
Evidence	
Other Info	
Instances	6
Solution	Ensure that your web server, application server, load balancer, etc. is configured to enforce Strict Transport-Security.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet https://owasp.org/www-community/Security-Headers https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security https://caniuse.com/stricttransportsecurity https://datatracker.ietf.org/doc/html/rfc6797
CWE Id	319
WASC Id	15
Plugin Id	10035

Low	Timestamp Disclosure - Unix
Description	A timestamp was disclosed by the application/web server. - Unix
URL	http://localhost:5173/.vite-cache/deps/react-dom_client.js?v=88899bc8
Node Name	http://localhost:5173/.vite-cache/deps/react-dom_client.js (v)
Method	GET
Attack	
Evidence	2080374784
Other Info	2080374784, which evaluates to: 2035-12-04 17:53:04.
URL	https://edge.microsoft.com/componentupdater/api/v1/update?cup2key=7:j9ld7_4OrmyCXKMl9t6eqGQRZxPH-ZvIoIEz5_jvnBc&cup2hreq=1badcc64097a8c682dcdb5005578dae26db2c0eb74cc6f00f6cf24c8
Node Name	https://edge.microsoft.com/componentupdater/api/v1/update (cup2hreq,cup2key)({request:{@os:@updater,acceptformat,apps:[{appid,brand,cohort,enabled,installdate,lang,ping:{r},targetingattributes,{AppCohort,AppMajorVersion,AppRollout,AppVersion,IsInternalUser,Priority,Updater,UpdaterVersion,updatecheck:{},version}],arch,dedup,domainjoined,hw:{avx,physmemory,sse,sse2,sse3,sse41,sse42,sse43,ismachine,os:{arch,platform,version},prodversion,protocol,requestid,sessionid,updaters:{autoupdatecheckenabled,ismachine,lastchecked,laststarted,name,updatepolicy,version},updaterversion}}})
Method	POST
Attack	
Evidence	1779318672
Other Info	1779318672, which evaluates to: 2026-05-21 07:11:12.
Instances	2
Solution	Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.
Reference	https://cwe.mitre.org/data/definitions/200.html
CWE Id	497
WASC Id	13
Plugin Id	10096

Low	X-Content-Type-Options Header Missing
------------	--

Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://localhost:5173/
Node Name	http://localhost:5173/
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:5173/robots.txt
Node Name	http://localhost:5173/robots.txt
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:5173/sitemap.xml
Node Name	http://localhost:5173/sitemap.xml
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:5173/src/main.jsx
Node Name	http://localhost:5173/src/main.jsx
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:5173/vite.svg

Node Name	http://localhost:5173/vite.svg
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://edge.microsoft.com/serviceexperimentation/v3/?osname=win&channel=stable&osver=10.0.26200&devicefamily=desktop&installdate=1767830724&clientversion=148.0.3967.70&experimentationmode=2&scpguard=0&scpfll=0&scpver=0
Node Name	https://edge.microsoft.com/serviceexperimentation/v3/ (channel,clientversion,devicefamily,experimentationmode,installdate,osname,osver,scpfll,scpguard,scpver)
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/settings/3
Node Name	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/settings/3 ()({identity: {user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUris,edgeSettings,customSettings}}},correlationId,debugInfo:{clientId}})
Method	POST
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/toptraffic/3
Node Name	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/toptraffic/3 ()({identity: {user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUris,edgeSettings,customSettings}}},correlationId,debugInfo:{clientId}})
Method	POST
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://nav-edge.smartscreen.microsoft.com/api/browser/edge/navigate/3

Node Name	<code>https://nav-edge.smartscreen.microsoft.com/api/browser/edge/navigate/3 ()({userAgent, redirectChain:[],enhancedRedirectChain:{redirectSource,referrerChain:[]},identity:{user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUri,edgeSettings,customSettings}}},config:{user:{uriReputation:{enforcedByPolicy,level}},device:{appControl:{level},appReputation:{enforcedByPolicy,level}}},destination:{uri,ip},...)</code>
Method	POST
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	Systemic
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security_Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Information Disclosure - Sensitive Information in URL
Description	The request appeared to contain sensitive information leaked in the URL. This can violate PCI and most organizational compliance policies. You can configure the list of strings for this check to add or remove values specific to your environment.
URL	http://localhost:5173/?token=EHa4cV9nJxKL
Node Name	http://localhost:5173/ (token)
Method	GET
Attack	
Evidence	token
Other Info	The URL contains potentially sensitive information. The following string was found via the pattern: token token
Instances	1
Solution	Do not pass sensitive information in URIs.
Reference	
CWE Id	598
WASC Id	13
Plugin Id	10024

Informational	Information Disclosure - Suspicious Comments
Description	The response appears to contain suspicious comments which may help an attacker.

URL	http://localhost:5173/.vite-cache/deps/@supabase_supabase-js.js?v=70fb2df1
Node Name	http://localhost:5173/.vite-cache/deps/@supabase_supabase-js.js (v)
Method	GET
Attack	
Evidence	* @param options.db.schema You can swit
Other Info	The following pattern was used: \bDB\b and was detected in likely comment: "/* * Create a new client for use in the browser. * @param supabaseUrl The unique Supabase URL which is supplied when you cr", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/.vite-cache/deps/@supabase_supabase-js.js?v=70fb2df1
Node Name	http://localhost:5173/.vite-cache/deps/@supabase_supabase-js.js (v)
Method	GET
Attack	
Evidence	* Match only rows where `column` is equal t
Other Info	The following pattern was used: \bWHERE\b and was detected 28 times, the first in likely comment: "/* * Match only rows where `column` is equal to `value`. * * To check if the value of `column` is NULL, you should use `.`", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/.vite-cache/deps/@supabase_supabase-js.js?v=70fb2df1
Node Name	http://localhost:5173/.vite-cache/deps/@supabase_supabase-js.js (v)
Method	GET
Attack	
Evidence	/* * Creates an admin API client that can
Other Info	The following pattern was used: \bADMIN\b and was detected 2 times, the first in likely comment: "/* * Creates an admin API client that can be used to manage users and OAuth clients. * * @example * ``ts * impo", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/.vite-cache/deps/@supabase_supabase-js.js?v=70fb2df1
Node Name	http://localhost:5173/.vite-cache/deps/@supabase_supabase-js.js (v)
Method	GET
Attack	
Evidence	backs to react to a user joining or leaving
	The following pattern was used: \bUSER\b and was detected 29 times, the first in likely comment: "/*

Other Info	* Used to sync a diff of presence join and leave events from the * server, as they happen. * * Like `syncState`,", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/.vite-cache/deps/@supabase_supabase-js.js?v=70fb2df1
Node Name	http://localhost:5173/.vite-cache/deps/@supabase_supabase-js.js (v)
Method	GET
Attack	
Evidence	iting based on the 'username' unique column *
Other Info	The following pattern was used: \bUSERNAME\b and was detected in likely comment: "/* * Perform an UPSERT on the table or view. Depending on the column(s) passed * to `onConflict`, `.upsert()` allows you to", see evidence field for the suspicious comment /snippet.
URL	http://localhost:5173/.vite-cache/deps/@supabase_supabase-js.js?v=70fb2df1
Node Name	http://localhost:5173/.vite-cache/deps/@supabase_supabase-js.js (v)
Method	GET
Attack	
Evidence	s an error with the query, throwOnError will
Other Info	The following pattern was used: \bQUERY\b and was detected 24 times, the first in likely comment: "/* * If there's an error with the query, throwOnError will reject the promise by * throwing the error instead of returning ", see evidence field for the suspicious comment /snippet.
URL	http://localhost:5173/.vite-cache/deps/@supabase_supabase-js.js?v=70fb2df1
Node Name	http://localhost:5173/.vite-cache/deps/@supabase_supabase-js.js (v)
Method	GET
Attack	
Evidence	t, FunctionRegion } from '@supabase/function
Other Info	The following pattern was used: \bFROM\b and was detected 52 times, the first in likely comment: "/* * Creates a new Functions client bound to an Edge Functions URL. * * @example * ```ts * import { FunctionsCli", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/.vite-cache/deps/@supabase_supabase-js.js?v=70fb2df1
Node Name	http://localhost:5173/.vite-cache/deps/@supabase_supabase-js.js (v)

Method	GET
Attack	
Evidence	the call * with `.select()`. * * @param
Other Info	The following pattern was used: <code>\bSELECT\b</code> and was detected 3 times, the first in likely comment: <code>"/**</code> * Perform an INSERT into the table or view. * * By default, inserted rows are not returned. To return it, chain the <code>ca</code>", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/.vite-cache/deps/axios.js?v=b20d4076
Node Name	http://localhost:5173/.vite-cache/deps/axios.js (v)
Method	GET
Attack	
Evidence	remove interceptor later */
Other Info	The following pattern was used: <code>\bLATER\b</code> and was detected in likely comment: <code>"/**</code> * Add a new interceptor to the stack * * @param {Function} fulfilled The function to handle `then` for a `Promise` ", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/.vite-cache/deps/axios.js?v=b20d4076
Node Name	http://localhost:5173/.vite-cache/deps/axios.js (v)
Method	GET
Attack	
Evidence	move an interceptor from the stack * *
Other Info	The following pattern was used: <code>\bFROM\b</code> and was detected 4 times, the first in likely comment: <code>"/**</code> * Remove an interceptor from the stack * * @param {Number} id The ID that was returned by `use` * * @returns ", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/.vite-cache/deps/react-router-dom.js?v=c5c8eb85
Node Name	http://localhost:5173/.vite-cache/deps/react-router-dom.js (v)
Method	GET
Attack	
Evidence	* Access a value from the context. If no
	The following pattern was used: <code>\bFROM\b</code> and was detected 5 times, the first in likely comment: <code>"/**</code>

Other Info	* Access a value from the context. If no value has been set for the context, * it will return the context's `defaultVa", see evidence field for the suspicious comment /snippet.
URL	http://localhost:5173/.vite-cache/deps/react-router-dom.js?v=c5c8eb85
Node Name	http://localhost:5173/.vite-cache/deps/react-router-dom.js (v)
Method	GET
Attack	
Evidence	// TODO: This could be clea
Other Info	The following pattern was used: \bTODO\b and was detected 10 times, the first in likely comment: "// TODO: This could be cleaned up. push/replace should probably just take", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/.vite-cache/deps/react-router-dom.js?v=c5c8eb85
Node Name	http://localhost:5173/.vite-cache/deps/react-router-dom.js (v)
Method	GET
Attack	
Evidence	// where to stop which is al
Other Info	The following pattern was used: \bWHERE\b and was detected in likely comment: "// where to stop which is always at the root route in SPA mode", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/.vite-cache/deps/recharts.js?v=d842268b
Node Name	http://localhost:5173/.vite-cache/deps/recharts.js (v)
Method	GET
Attack	
Evidence	// TODO: make this better.
Other Info	The following pattern was used: \bTODO\b and was detected 2 times, the first in likely comment: "// TODO: make this better. For now, right arrow triggers "forward", left arrow "back"", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/.vite-cache/deps/recharts.js?v=d842268b
Node Name	http://localhost:5173/.vite-cache/deps/recharts.js (v)
Method	GET
Attack	
Evidence	cape - looks like a bug, should we pass par
Other Info	The following pattern was used: \bBUG\b and was detected in likely comment: "/* * Line is not passing parentViewBox to the LabelList so the labels can escape - looks like a bug, should we pass par", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/.vite-cache/deps/recharts.js?v=d842268b
Node Name	http://localhost:5173/.vite-cache/deps/recharts.js (v)
Method	GET
Attack	
Evidence	ribe the observable from the store, and prev

Other Info	The following pattern was used: \bFROM\b and was detected 18 times, the first in likely comment: "/* * The minimal observable subscription method. * @param observer Any object that can be used as an observer. ", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/@react-refresh
Node Name	http://localhost:5173/@react-refresh
Method	GET
Attack	
Evidence	// TODO: rename these field
Other Info	The following pattern was used: \bTODO\b and was detected in likely comment: "// TODO: rename these fields to something more meaningful.", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/@react-refresh
Node Name	http://localhost:5173/@react-refresh
Method	GET
Attack	
Evidence	ogic is copy-pasted from similar logic in th
Other Info	The following pattern was used: \bFROM\b and was detected 2 times, the first in likely comment: "// This logic is copy-pasted from similar logic in the DevTools backend.", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/api/auditApi.js
Node Name	http://localhost:5173/src/api/auditApi.js
Method	GET
Attack	
Evidence	am {string} params.from - start date YYYY
Other Info	The following pattern was used: \bFROM\b and was detected in likely comment: "/* * GET /api/audit/export — downloads audit logs as a CSV blob. * Only accessible by superadmins (server enforces). * ", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/api/authApi.js
Node Name	http://localhost:5173/src/api/authApi.js
Method	GET
Attack	
Evidence	ire this to backend later)
Other Info	The following pattern was used: \bLATER\b and was detected in likely comment: "// login (you will wire this to backend later)", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/api/deviceApi.js
Node	

Name	http://localhost:5173/src/api/deviceApi.js
Method	GET
Attack	
Evidence	+ loads config from DB
Other Info	The following pattern was used: \bDB\b and was detected 2 times, the first in likely comment: "// AP Toggle backend validates scan + loads config from DB ", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/api/deviceApi.js
Node Name	http://localhost:5173/src/api/deviceApi.js
Method	GET
Attack	
Evidence	// Admin State (authoritativ
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "// Admin State (authoritative AP + scan + portal + risk) ", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/api/deviceApi.js
Node Name	http://localhost:5173/src/api/deviceApi.js
Method	GET
Attack	
Evidence	ve State (real-time from Pi)
Other Info	The following pattern was used: \bFROM\b and was detected in likely comment: "// AP Live State (real-time from Pi) ", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/api/rasPiApi.js
Node Name	http://localhost:5173/src/api/rasPiApi.js
Method	GET
Attack	
Evidence	// Debug
Other Info	The following pattern was used: \bDEBUG\b and was detected in likely comment: "// Debug", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/api/rasPiApi.js
Node Name	http://localhost:5173/src/api/rasPiApi.js
Method	GET
Attack	
Evidence	// POST metadata from rasPi
Other Info	The following pattern was used: \bFROM\b and was detected in likely comment: "// POST metadata from rasPi", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/api/samApi.js
Node Name	http://localhost:5173/src/api/samApi.js
Method	GET
Attack	
Evidence	ndpoints for future DB data export const

Other Info	The following pattern was used: \bDB\b and was detected in likely comment: <code>/* // api /samApi.js</code> import api from <code>"/axios"</code>; export const getThreats = () => api.get(<code>"/sam/threats"</code>); export const getVul", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/api/userApi.js
Node Name	http://localhost:5173/src/api/userApi.js
Method	GET
Attack	
Evidence	// UPDATE user - no backend code y
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: <code>// UPDATE user - no backend code yet"</code>, see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/components/accounts/UserForm.jsx
Node Name	http://localhost:5173/src/components/accounts/UserForm.jsx
Method	GET
Attack	
Evidence	// Pass this prop from parent to check per
Other Info	The following pattern was used: \bFROM\b and was detected in likely comment: <code>// Pass this prop from parent to check permissions"</code>, see evidence field for the suspicious comment /snippet.
URL	http://localhost:5173/src/components/accounts/UserForm.jsx
Node Name	http://localhost:5173/src/components/accounts/UserForm.jsx
Method	GET
Attack	
Evidence	e legacy "staff" "user"
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: <code>// Migrate legacy "staff" "user"</code>", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/hooks/useAuditLogs.js
Node Name	http://localhost:5173/src/hooks/useAuditLogs.js
Method	GET
Attack	
Evidence	aginated audit logs from the backend. * Su
Other Info	The following pattern was used: \bFROM\b and was detected 2 times, the first in likely comment: <code>/***</code> * useAuditLogs * ----- * Fetches paginated audit logs from the backend. * Supports search, status filte", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/hooks/useDashboard.js

Node Name	http://localhost:5173/src/hooks/useDashboard.js
Method	GET
Attack	
Evidence	// scanList comes from the per-network res
Other Info	The following pattern was used: \bFROM\b and was detected in likely comment: "// scanList comes from the per-network response", see evidence field for the suspicious comment /snippet.
URL	http://localhost:5173/src/hooks/useDevice.js
Node Name	http://localhost:5173/src/hooks/useDevice.js
Method	GET
Attack	
Evidence	/ without requiring user interaction. Stops
Other Info	The following pattern was used: \bUSER\b and was detected 3 times, the first in likely comment: "// without requiring user interaction. Stops when AP is off or unmounted.", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/hooks/useDevice.js
Node Name	http://localhost:5173/src/hooks/useDevice.js
Method	GET
Attack	
Evidence	// Admin state from /network
Other Info	The following pattern was used: \bADMIN\b and was detected 4 times, the first in likely comment: "// Admin state from /network/:id/state (source of truth)", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/hooks/useDevice.js
Node Name	http://localhost:5173/src/hooks/useDevice.js
Method	GET
Attack	
Evidence	etch network config from Supabase
Other Info	The following pattern was used: \bFROM\b and was detected 2 times, the first in likely comment: "// Fetch network config from Supabase ", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/hooks/useDevice.js
Node Name	http://localhost:5173/src/hooks/useDevice.js
Method	GET
Attack	
Evidence	ooks/useDevice.js - DB-driven AP state + a
Other Info	The following pattern was used: \bDB\b and was detected 6 times, the first in likely comment: "// hooks/useDevice.js - DB-driven AP state + admin state from /network/:id /state", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/hooks/useProfile.js
Node Name	http://localhost:5173/src/hooks/useProfile.js
Method	GET

Attack	
Evidence	// Get profile data from backend (Bearer tok
Other Info	The following pattern was used: \bFROM\b and was detected in likely comment: "// Get profile data from backend (Bearer token attached by axios interceptor)", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/hooks/useSAM.js
Node Name	http://localhost:5173/src/hooks/useSAM.js
Method	GET
Attack	
Evidence	// Check if the user previously cleared
Other Info	The following pattern was used: \bUSER\b and was detected 2 times, the first in likely comment: "// Check if the user previously cleared results for this BSSID", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/hooks/useSAM.js
Node Name	http://localhost:5173/src/hooks/useSAM.js
Method	GET
Attack	
Evidence	// TODO: uncomment when bac
Other Info	The following pattern was used: \bTODO\b and was detected in likely comment: "// TODO: uncomment when backend is ready", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/hooks/useSAM.js
Node Name	http://localhost:5173/src/hooks/useSAM.js
Method	GET
Attack	
Evidence	eState, useEffect } from "react";
Other Info	The following pattern was used: \bFROM\b and was detected 12 times, the first in likely comment: "//import { useState, useEffect } from 'react';", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/hooks/useSAM.js
Node Name	http://localhost:5173/src/hooks/useSAM.js
Method	GET
Attack	
Evidence	g rich details from DB via API
Other Info	The following pattern was used: \bDB\b and was detected 2 times, the first in likely comment: "// Try fetching rich details from DB via API", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/hooks/useSessionState.js
Node Name	http://localhost:5173/src/hooks/useSessionState.js
Method	GET
Attack	
Evidence	/** * Read a key from sessionStorage, JSO

Other Info	The following pattern was used: <code>\bFROM\b</code> and was detected 3 times, the first in likely comment: <code>"/**</code> * Read a key from sessionStorage, JSON-parse it, and return the value. * Returns <code>`fallback`</code> if the key is missing, empty", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/hooks/useUsers.js
Node Name	http://localhost:5173/src/hooks/useUsers.js
Method	GET
Attack	
Evidence	// CREATE – Add new user
Other Info	The following pattern was used: <code>\bUSER\b</code> and was detected 5 times, the first in likely comment: <code>"/ CREATE – Add new user"</code>, see evidence field for the suspicious comment /snippet.
URL	http://localhost:5173/src/utills/pollUntil.js
Node Name	http://localhost:5173/src/utills/pollUntil.js
Method	GET
Attack	
Evidence	the first response where <code>`isDone(data)`</code> retu
Other Info	The following pattern was used: <code>\bWHERE\b</code> and was detected in likely comment: <code>"/ Returns the first response where `isDone(data)` returns true,"</code>, see evidence field for the suspicious comment/snippet.
Instances	43
Solution	Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.
Reference	
CWE Id	615
WASC Id	13
Plugin Id	10027

Informational	Modern Web Application
Description	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.
URL	http://localhost:5173/
Node Name	http://localhost:5173/
Method	GET
Attack	
Evidence	<pre><script type="module">import { injectIntoGlobalHook } from "@react-refresh"; injectIntoGlobalHook(window); window.\$RefreshReg\$ = () => {}; window.\$RefreshSig\$ = () => (type) => type;</script></pre>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://localhost:5173/robots.txt
Node Name	http://localhost:5173/robots.txt
Method	GET

Attack	
Evidence	<code><script type="module">import { injectIntoGlobalHook } from "/@react-refresh"; injectIntoGlobalHook(window); window.\$RefreshReg\$ = () => {}; window.\$RefreshSig\$ = () => (type) => type;</script></code>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://localhost:5173/sitemap.xml
Node Name	http://localhost:5173/sitemap.xml
Method	GET
Attack	
Evidence	<code><script type="module">import { injectIntoGlobalHook } from "/@react-refresh"; injectIntoGlobalHook(window); window.\$RefreshReg\$ = () => {}; window.\$RefreshSig\$ = () => (type) => type;</script></code>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
Instances	3
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109